

Threat Actors: 2.1

The entity responsible for an event that has an impact on the safety of another entity

- Also called a malicious actor

Threat actor attributes

- Describes the characteristics of the actor

Used to categorize the motivation

- Why is the attack happening

- Is this directed or random

Attributes of threat Actors:

Internal/External

- The attackers inside the house

- The attacker is outside the base trying to get in.

Resources/Funding

- No money

- Extensive funds

Level of Sophistication/ Capability

- Blindly run scripts or automated vulnerability scan

- Can write their own attack/malware scripts

Motivations Of Threat Actors:

Many, Some including:

Data Exfiltration, Espionage, Blackmail, Revenge, Chaos, Financial Gain, Or War.

Nation States:

External Entity

- Government and National Security

Many Possible Motivations:

- Data exfiltration, Espionage, War

Constant attacks, massive resources

- Commonly an Advanced Persistent Threat (APT)

Highest Sophistication

- Military Control, Utilities, Financial Control

- U.S. and Israel destroyed 1,000 nuclear centrifuges with the Stuxnet worm

Unskilled Attackers:

Runs pre-made scripts without any knowledge of what's occurring

- Anyone can do this

Motivated by the hunt

Mostly External, but at times internal

Not Sophisticated, No Formal Funding

Hacktivist:

A hacker with a Purpose

- Motivated by Philosophy, Revenge, disruption, etc.

Often an external entity, could possibly infiltrate

Can be remarkably sophisticated

- Very specific hacks
- Dos, Web Service defacing, doc release

Funding may be limited still

Insider Threat:

Motivated by revenge, or financial gain

Extensive Resources: All of the organization at their disposal

An internal entity, eating away from inside

Medium level of sophistication, but excels with company knowledge

Organized Crime:

Professional Criminals

- Motivated by money, almost always an external entity

Very sophisticated: Best hacking money can buy

Extremely organized: One person hacks, another manages exploits, another sells the data, etc...

Lots of funding

Shadow IT:

Going rogue

- Working around the IT department
- Builds their own infrastructure

Information Technology Can Put up Roadblocks

Limited Resources, and Medium Security

Threat Actor	ATTRIBUTES			
	Location	Sophistication	Resources	Potential Motivations
Unskilled	External	Very low	Limited	Disruption, data exfiltration, Political beliefs
Hactivist	External	Can be high	Some	Philosophical/Political beliefs/ chaos
Insider threat	Internal	Medium	Man/	Revenge, Money
Organized crime	External	Very high	Extensive	Financial gain
Shadow IT	Internal	Limited	Man/	Revenge, Beliefs
Nation state	External	Very high	Extensive	War, disruption, Data Exfiltration

Common Threat Vectors 2.2

A Method that an attacker uses to Gain Access to Your Systems.

- Also referred to as Attack Vectors

A lot of work goes into finding Vulnerabilities in these Vectors

IT Security Professionals Spend their Career Walking these Vectors.

Message-Based Vectors:

One of the biggest (and most successful threat vectors)

Email: Malicious links to an email

SMS (Short Message Service): Attacks in a text

Message Based Vectors:

Phishing Attacks

- People want to click links

- Send link in an email or text

Deliver the malware to the user

- Attach it to the email

- Scan all attachments, NEVER open unknown links

Social Engineering Attacks:

- Invoice Scams

- Cryptocurrency Scams

Image-Based Vectors:

Easy to identify a text-based threat

- Its more difficult to identify the threat in an image

Some image formats can be dangerous

- The SVG (Scalable Vector Graphic) format
- Image is described in XML (Extensible Markup Language)

Significant Security Concerns:

- HTML injection
- JavaScript attack code

Browsers must provide input validation

- Allows running malicious code

XSS: Cross-Site Scripting

File Based Vectors:

More than just executables

Adobe PDF

- A file format containing other objects

ZIP/Rar (or any compression types)

Microsoft Office

- Documents with macros
- Add in files

Voice Call Vectors:

Vishing: Phishing over the Phone

SPoM over IP: Large scale Phone Calls

War dialing

Call tampering: Disrupting Voice calls

Removable Device Vectors:

Getting around the Firewall

- The USB interface

Malicious Software USB flash drives

• Infect air gapped networks

USB drives can Act as keyboard

- Hackers on a chip

Data Exfiltration:

- Terabytes of data Walk out the door

- Zero bandwidth usage

Vulnerable Software Vectors:

Client Based

- Infected Executable
- Known / or Unknown Vulnerabilities
- May need constant updates

Agentic

- No installed executable
- Compromised software on the server on the server hand offer all users
- Client runs a new instance each time

Unsupported System Vectors:

Patching is an important prevention tool

Unsupported systems aren't patched

Outdated operating systems

A single system could be an entry point

- Keep inventory records straight

Unsecure Network Vectors:

The Network connects everything

- Ease of Access for the attackers

Wireless

- Outdated Security Protocols (WEP, WPA, WPA2)

Wired: Unsecured Interfaces - No 802.1X

Bluetooth is even a Winchance

Open Source Ports:

Most Network based Services Connect over a TCP or UDP Port

- An "Open" Port

Every Open Port is an opportunity for the hacker

- Application Vulnerability or Misconfiguration

Every application has their own open port

- More Services Expand the attack Services

Firewall rules

- Must allow traffic to an open port

Default Credentials:

Username: admin, Password: admin

Very easy to find default Credentials

Supply Chain Vectors:

Tamper with Underlying Infrastructure

- Or Manufacturing Process

Managed Service Provider (MSP)

- Allow Many different Customer Networks

Gain Access to a Network from a Vendor

- 2013 Target credit card breach

Suppliers:

- Counterfeit Network equipment

- Install backdoors

- 2020 - Fake Cisco Catalyst switches

Phishing: 2.2

Social Engineering with a touch of spoofing

- Often delivered by email, text, etc...
- Very penetrable when well done

Don't be fooled: Check the URL

Usually something is not quite right

Business Email Compromise:

We trust email sources

- The attackers take advantage of the trust

Spoofed Email Address

- Not a really legitimate email address

Financial Fraud

- Sends emails with updated bank information

Tricks and Misdirection:

How are they so successful

- Digital sight of hand

Typo-squatting: A type of URL hijacking

- <https://professor.mess@1.com>

Prebaiting: Lying very effectively in a situation they create

Phishing with different bait:

- Vishing (Voice Phishing) is done over the Phone OR Voicemail
- Caller ID spoofing is common
- Fake Security Checks or Bank Alerts

Smishing (SMS Phishing) is done by text Messaging

- Asking for Personal information

Variations on a theme:

- The Fake Check Scam, Prize Verification Scam, Boys/Girls Scam
- Some Great Examples on reddit/scams

Impersonation: 2.2

Before the attack, the trap is set

- There is an act and a story

"Hello im X from X this is an urgent call..."

Attackers Pretending to be someone they aren't

Use some of those details from reconnaissance

Pretend to be higher in rank

Use technician jargon, or be a buddy

Eligible Information:

Extracting information from the victim

- The victim is unaware this is occurring

Often seen in phishing

Well documented Psychological techniques not just "hey whats your password"

Identity Fraud:

Your identity can be used by others

Credit Card Fraud: Opening account in your name, Or using Your credit card information

Opening Bank Account in Your Name

Loan Fraud, Under Your Name

Government Benefit frauds

- Tax returns

Protect Against Impersonation:

Never Volunteer information

- My Password is x

Don't disclose Personal details

- Bad guys are tricky,

Always Verify before revealing information

- Call back, Verify through third parties

Verification Should be encouraged

- Especially if your Org contains valuable information

Watering-Hole Attack:

What if your network was really secure

- You didn't even plug in that floppy or USB

The attackers can't get in... right?

Have the mountain come to you:

- Go to where the mountain hole hangs out
- Requires research

Executing the watering hole attack:

Determine which website which the victim group uses

- Educated guess - local sandwich shop or coffee shop

Infect the third party site → Infect target

Only looking for specific victims (Your company)

Watching the Watering-Hole:

Defense - in-depth:

- Layered defense

- Never one thing

Firewalls and IPS

- Stop the network traffic before it gets bad

Anti-virus / Anti-malware

Other Social Engineering Attacks: 2.2

Misinformation / Disinformation

- Disseminate socially incorrect information

- Influence companies, social, public opinion or political opinions

Nation State Actors: divide, distract & persuade

Advertising is a method, as well as Social Media

Misinformation Process:

Create Fake Users → Create Content → Post on Social Media → Amplify Message → Real users share the media → Mass media report

Brand Impersonation:

Pretend to be a well known brand

- Apple, Google, etc

Create tens of thousands of impersonated sites

Visitors are presented with pop-ups

Malware is almost guaranteed now

Memory Injection: 2.3

Finding Malware:

Malware runs in memory

- Memory Forensics can locate Malicious Code

Memory Contains Running Processes

- DLL (Dynamic Link Libraries)

- Threads

- Buffers

- Memory Management Structures

Malware is hidden somewhere

- Malware runs its own process

- Malware injects itself into a legitimate process

Memory Injection:

- Add code into memory of an existing process

- Gets data across in the process, some processes

DLL Injection:

Dynamic Link Library: Windows library containing code and data

One of the most popular injection methods

Attackers inject a part to malicious DLL

Buffer Overflows: 2.3

- Overwriting a buffer or memory
- Spills over into other memory

Developers need to perform bounds checking

- The attackers spend a lot of time looking for openings

Not a simple exploit

A good buffer overflow is rare and effective

Can be used to gain administrator access

Race Conditions: 2.3

A Programming Condition when two events occur at nearly the same time.

- Very bad if not planned for

Time-of-check-to-time-of-use attack (TOCTOU)

- Check the system

- When do you use results of your last check

- Something may occur between check and use

Race Conditions can cause big problems:

- January 2004 - Mars Rover "Spirit"

- Robot when problem was identifying

- Infinite loop

TOCTOU attack against Tesla using Bluetooth

Malicious Updates: 2.3

Software Updates

Always keep your OS updated?

Not all updates are secure

Follow best practices

- Always have a known backup
- Install from trusted sources
- BACKUP!!!

Downloading + Updating:

Install updates from a downloaded file

- Always consider your actions

Confirm the source

- A random pop-up during web browsing may not be legitimate

Visit the developer's site directly

- Don't trust a random update button or randomly downloaded file

Many operating systems will only allow signed apps

- Don't disable your security controls

Automatic Updates:

The app updates itself

- Often includes Security Checks / digital Signature

Relatively Software

- Comes directly from developer

Not Perfect, SolarWinds Orion Supply Chain Attack 2020

- Gained Access to hundreds of government agencies and companies

Operating System Vulnerabilities: 2.3

A Foundational Computing Platform

- EVERYbody uses an OS
- Rendered a huge target

Remarkably Complex:

- Millions of lines of code
- More code means more opportunities for security issues

The vulnerabilities are already there, we just haven't found them yet

A Month of OS Updates:

A Normal Month of Windows Updates

- Patch Tuesday - 2nd Tuesday of the month

May 9, 2023 - Nearly 50 Patches

- 8 Elevation of Privilege Vulnerabilities
- 5 DPs ...
- 12 Remote Code ...

Best Practices for OS Vulnerabilities:

Always Update ASAP

- Race between you and the attackers

Perform a test prior to deployment

May require a reboot.

SQL injection: 2.3

Code injection

- Adding your own information into a data stream

Enables due to low programming

- The application should properly handle input/output

So many different data types:

HTML, SQL, XML, LDAP, etc.

SQL injection:

SQL - Structured Query Language

- The most common relational database management system language

SQL injection (SQLi)

- Put your own SQL queries in an existing application

- Application should be allowed

Can often be injected in the web browser

OR '1'='1'

Can be egregious

- Add users DDos

SQL injection demonstration:

Employee: Smith

Authentication TAN: 85L99A

Employee Name: Smith

Authentication TAN: 85L99A or '1'='1'

Cross-Site Scripting (XSS) : 2.3

XSS NOT CSS (Cascading Style Sheets)

Originally called XSS because of browser security flaws

- Information from one site could be shared with another

One of the most common web app vulnerabilities

Takes advantage from trust a user has for a site

XSS commonly uses JavaScript

Non-Persistent (Reflected) XSS Attack

Web site allows scripts to run in user input

- Search box is a common source

Attacker emails a link that takes advantage of this vulnerability

- Runs a script that sends credentials/session ID/cookies to the attacker

Script Embeds in URL executes in the victim's browser

- As if it came from the server

Attacker uses credentials/session IDs/cookies to steal victim information without their knowledge

Persistent (Stored) XSS Attack:

Attacker posts a message to a social network

- Includes the malicious payload

It's now "Persistent"

- Everyone gets the payload

No specific target, everyone gets the page

For social networking this can spread extremely quickly

Hacking a Sudo:

June 2017, Aaron Guzman

When authenticating with Sudo, user gets a token

A valid token would let you use Sudo without a password

Allows full access to Vagrant

Protecting against XSS:

Be careful when clicking links

Consider disabling/limiting JS

Keep browser and apps updated

Validate input

Hardware Vulnerabilities: 2.3

We are surrounded by hardware devices

- Many do not have an accessible OS

These devices are potential security issues

- Perfect entry point for attack

Everything is connected to the network - Light Bulbs, Garage doors etc...

Firmware:

The Software inside the hardware

Vendors are the only ones who can fix their hardware

- Assuming they even know how

Trane Comfortlink II thermostats

- Control temp from phone

- Took a year to patch

End-of-Life (EOL)

- Manufacturer stops selling a product

- May be time to replace the device

EOL (End of Service life)

- Manufacturer stops providing service

- May have Premium support

EOL is Primary concern

Legacy Platforms:

Some devices remain installed for a long time

May be running at EoL/EoS

Old OS, Applications, or middleware

May be hard to replace

Mitigate issues with additional security

- Additional firewall rules

- IPS signatures

Virtualization Vulnerabilities: 2.3

Virtualization Security:

Quite different than non-virtual machines

- Can appear anywhere

Quantity of resources vary between VMs

- CPU, Memory, Storage

More similarities to physical machines

- Complexity adds opportunity for attackers

Virtualization Vulnerabilities

- Local privilege escalation
- Command injection
- Information disclosure

VM Escape Protection:

The Virtual Machine is self contained

- There IS a way out

Virtual Machine Escape.

- Once you escape, it's a huge exploit

Escape the VM:

Using Javascript engine bug in Microsoft Edge

- Code execution in the Edge Sandbox

Exploiting Windows kernel Bugs

Resource Reuse:

The Hypervisor Manages relationship between Physical and Virtual Resources

These Resources can be reused between VMs

- Data shared from Hypervisor between Machines

Data can individually be shared between VMs

- Time to update the Memory

Cloud Specific Vulnerabilities: 2.3

Security in the Cloud

Cloud Adaptation is nearly universal

We store sensitive data in the cloud

We're not putting in the correct protections

Simple best practices are NOT being used.

Attack the Service:

DOS (Denial of Service)

- Fundamental Attack Type

Authentication Bypass

- Take advantage of a weak or faulty authentication

Directory Traversal

Remote code execution is possible

Attack the Application:

Web application attacks have increased

- Log4j and Spring cloud Function

Cross Site Scripting (XSS)

- Leverage poor input validation

Out-Of-Bounds Write

SQL-Injection. Getting direct Access to a database

Supply-Chain Vulnerabilities: 2.3

The chain contains many moving parts

- Raw materials, Suppliers, Manufacturer

Attackers can infect at any step along the way

- Infect different parts of the chain without detection

One exploit can affect the entire chain

Service Provider:

You can control your own security posture

- You can't always control a service provider

Service providers often have access to internal services

- An opportunity for the attacker

Many different types of providers

- Network, Utility, Office cleaning, Payroll/accounts

Consider ongoing security audits

Target Service Provider Attacks:

40 million credit cards stolen

Malware affected HVAC systems

HVAC sends network with cash registers

Put malware on all credit cards

Hardware Providers:

Can you trust your Next Service / Product / Software

Use a smaller Supplier base that you test

Strict Controls over Privileges and Access

Treat it as unfriendly initially

Cisco or Not Cisco?

All Network traffic flows through switches & routers

July 2022 - DHS arrest router CEO

- Sold more than 1 billion of components Cisco products

Knock offs made in China.

Software Providers:

Trust is a foundation of security

Cross-reference digital signature

How secure are updates? Automatic?

Open source is NOT immune

- Compromises the source code itself

SolarWinds Supply Chain Attack:

SolarWinds Origin

- Used by 18,000 customers
- Fortune 500 and several governments

Software updates compromised in March and June of 2020

Additional breaches took advantage of the exploit

- Microsoft, Cisco, Intel...

Misconfiguration Vulnerabilities: 2.3

Open Permissions:

Very easy to leave a door open

- Hackers will find it

Increasingly Common with cloud storage

June 2017: 14 Million Verizon Records Exposed

- Researcher found the data first

Unsecured Admin Account:

The linux root account / Windows Admin account

Can be a misconfiguration

- Internally configuring an easy password

Disabling direct login to the root account

Protect Accounts with root or Admin access

Insecure Protocols:

Some protocols aren't encrypted

- Telnet, FTP, SMTP, IMAP

Verify Security with Packet Capture

Secure versions: SSH, SFTP, IMAPS...etc...

Default Settings:

Every application and network device has a default login

- Many of these are never changed

Micro Botnet:

Takes advantage of default configurations

Takes Over Internet of things (IoT) devices

Got default configs

Cameras, routers, dumbbells, etc

Open Source: Good and bad

Open Ports + Services

Services will open ports

- Important to manage access

Often managed with a firewall

- Manage traffic flow

- Allow or deny based on port number or application

Firewall Ruleset can be complex, easy to make a mistake

Always test and audit

Mobile Device Vulnerabilities: 2.3

Challenging to Secure

- Often Need additional Security

Relatively Small

Always Moving

Packed with Sensitive data

Jailbreak / Rooting:

Mobile devices are Purpose built systems

- No OS Access

Gaining Access:

Android: Rooting

Apple: Jailbreaking

Install Custom Firmware

MDM (Mobile Device Manager) becomes useless

Sideloadng:

Malicious apps can be a huge concern

- One Trojan horse can warrant a data breach

Sideloadng: Installing applications, downloads from friends/secondary app.

Circumvents Security

Zero-Day Vulnerabilities: 2.3

Many Applications have Vulnerabilities

Attackers keep them yet to be discovered attacker secret

'Went to leverage them for personal gain

Zero-Day Attacks:

Attackers Search for Unknown Vulnerabilities

The Vendor has no idea

Zero Day Attack: An attack without a patch or Method of mitigation

Becomes a race to exploit / Patch

Difficult to defend against Unknown

Zero-Day Attacks in the Wild:

April 2023: Chrome Zero day

May 2023 - Microsoft ~~Zero~~ Day Patch

May 2023 - Apple iOS and iPad OS

An Overview of Malware: 2.4

Malicious Software (Very broad)

• Can be egregious

Gather information: keystrokes

Show you advertisements

Viruses / Worms

Malware title and Methods:

Viruses

Worms

Ransomware

Trojan Horse

Rootkit

Keylogger

SPYware

Bloatware

Logic Bomb

How you get malware:

These can work together:

- Worm takes advantage of a vulnerability
- Installs malware that includes a root access backdoor

Your Computer must Run a Program

- Email link
- Web pop up
- Drive by downloads
- Worm

Your Computer is Vulnerable

- OS updates
- Apps

Your data is Valuable:

Personal Data

Organization Wants

May hold a Ransom

Ransomware:

Particularly bad

- Your data is encrypted until you pay

OS works like normal

They want you running, *Not* working

You **MUST** pay the attackers to obtain the encryption key

- Unrecoverable Payment System

Protecting against Ransomware:

Always have a backup

Keep your OS up to date

Keep apps up to date

Keep your anti-virus/malware up to date

Keep **EVERYTHING** up to date

Viruses and Worms: 2.4

Virus: Malware that can reproduce itself

Needs you to create a program

Reproduces through file systems on the network

May or may not cause problems

Anti-virus is extremely common

Virus Types:

Program Virus: Part of the application

Boot Sector Virus: Who needs an OS

Script Viruses: Operating System and browser

Macro Viruses: Common in Microsoft Office

Filless Virus:

A stealth attack, avoids anti-virus

Operates in memory but never in file or application

Worms:

Malware that self-replicates without you doing any

Self-propagates and spreads across networks

Can spread over any systems

Firewalls help, but only as preventative tools

Spyware + Blootware: 2.9

Malware that spies on you

- Advertising, identity theft, affiliate fraud

Can trick you into installing

- Peer to Peer, Fake Security Software

Browser Monitoring

- Capture surfing definition

Keyloggers:

- Capture every keystroke
- Send your keystrokes back to the attacker

Protecting against Spyware:

Maintain your anti-virus / anti malware

- Always have the latest signatures

Always know what you're installing

- And watch your options during installation

Where's your backup? You may need it later

Run some scans

Bloatware:

A new computer or phone

- Includes the OS and other important apps
- Also includes applications you don't expect/need

Apps are installed by manufacturer

- You have no choice!

Uses valuable storage space

- Could slow system

Remove Bloatware:

Identify + Remove

Use the built in uninstaller

Some apps have their own uninstaller

Third Party Uninstallers are available if needed

Other Malware types: 2.4

Keyloggers:

Your keystrokes contain valuable information

- Website login URLs, Passwords, email Messages

Save all your input

Circumvent encryption Protections

Other data logging

- Clipboard logging, Screen logging, instant Messaging, Search engine queries

Logic Bomb:

Waits for a predefined time

Time Bomb: Time or date

User event: Logic bomb

Difficult to identify

- Difficult to repair if it detonates

Real-World Logic Bombs:

March 14, 2013 South Korea

- Email with malicious attachment Reached bank email

March 26, 2013 2pm local time

- Bomb detonates

- Stems and most lost data

Preventing a logic bomb:

Difficult to Recognize

- Each is Unique
- No Preferred Signatures

Processes + Procedures

- Formal Change Control

Electronic Monitoring: Alert on Changes

Constant Auditing: An administrator can circumvent

Rootkit:

Originally a Unix technique

- The root in rootkit

Modifies Core System Files

- Part of the kernel

Can be invisible to the operating system

- Won't see it in task manager

Also invisible to anti virus

Finding and removing rootkit:

Look for the unusual

Use a remover specific to the rootkit

Secure boot with UEFI.

Physical Attacks: 2.4

Old School Security

- No Keyboard, Mouse, or Command line

Many different ways to circumvent digital security

- A Physical Approach must be considered

If you have physical access to a server you have full control

Door locks only keep out honest people

Brute Force:

The Physical Version

Push through the obstruction

Check your Physical Security

RFID Cloning:

RFID Cloning

- Access Badges

- Key Fobs

Duplicators are on Amazon

The duplication process takes seconds

This is why we have NSA

Environmental Attack:

Attack everywhere Supporting the technology

- The operating environment

Power Monitoring

- Obvious Attack

HVAC (Heating, Ventilation and Air Conditioning) and humidity control

Large centres must be adequately cooled

Fire Suppression

- Watch for smoke or fire

Denial of Service: 2.4

Force a Service to fail

- Overload a Service

Take advantage of known failure or vulnerability

Competitive Advantage

Could be used as a distraction

Could be simple power outage

A Friendly Dos:

Unintentional Dos

Network Dos

- Loop without stop

Bandwidth Dos

- Downloading multiple-gigabyte linked documents over this line

Distributed Denial of Service (DDoS):

Launch an army of computers to bring down a server

This is why attackers have botnets

Thousands or millions of computers at your command

Asymmetric Threat: Few Resources can take down

DDoS Reflection and Amplification:

Turn Your Small attack into a large attack

- Often reflected off another device or service

An increasingly common Network DDoS technique

Uses Protocols with little authentication

- NTP, DNS, ICMP

DNS Attacks: 2.4

DNS Poisoning:

Modify the DNS Server

- Requires some crypto hacking

Modify the client host file

- The host file takes precedence over DNS queries

Sends fake response to a valid DNS request

Requires a reflection of the original request or resulting response

Domain Hijacking:

Get Access to the domain registration and you have control where the traffic flows

- Determine the DNS Names and DNS IP Address

Many ways to get in

- Brute force
- Socially engineer Password

Domain Hijacking:

Sunday October 22, 2016 11pm

Domain Name registrations of 36 domains are owned

Bank had 5 million customers and 27 billion in assets

URL Hijacking:

Make money from their mistakes

Sell badly states to the actual owner

OR Sell to competitor

Phishing Site

Infect a device with malware

Types of URL hijacking:

TypoSquatting / brandjacking

- Takes advantage of poor spelling

Country mistaking

A typing error

A different phrase

Different top-level domain

Website.org

Wireless Attacks: 2.4

Surfing along wireless network

- Connection drops
- Keystrokes

You may not be able to stop it

Wireless deauthentication

802.11 Management frames:

802.11 Wireless attacks include a number of features

- Frames that have encryption keys

Important for the operation of 802.11

- How to find access points, Manage QoS

Original Wireless Standards did not add Protection for management frames

Protecting against deauth attacks:

IEEE has addressed the issue with 802.11ac

Some of the important management frames are encrypted

Not everything is encrypted

Radio Frequency (RF) jamming:

Denial of Service

- Prevent wireless communication

Transmit interfering wireless signals

- Decoding signal to noise ratio

Sometimes it's not intentional

- Interference not jamming

Jamming IS intentional

Wireless Jamming:

Many different types

- Constant random bits / Constant legitimate freq
- Data sent at random times - Random data are legitimate freq
- Reactive jammer only when someone else tries to communicate

Needs to be somewhere close

Time to go for hours

- Hurt down the jammer

On-Path Attack: 2.4

How can an attacker watch you without you knowing?

- Formerly known as Man-in-the-Middle

Redirects your traffic

- Never aware the attack is occurring

ARP Poisoning:

- On Path attack has the local IP Stealer

On-Path browser attack:

What if the Malicious was on the same computer as the victim?

- Malware/Trojan Horse does All the Proxy Work

- Formerly known as Man in the browser

Huge Advantages for the attacker

- Relatively easy to proxy encrypted traffic
- Everything looks normal to the victim

The Malware in your browser waits for you to login to your bank

- Then steals you out

Replay-Attacks: 2.4

User information is transmitted over the network

- A crafty hacker will take advantage of this

Needs Access to the raw network data

Network tap, ARP Poisoning, Malware on the victim's computer

The gathered information may help the attacker

- Replay the data to somebody else

This is not an on-path attack

- The actual replay does not reach the original workstation

- Can be avoided with encryption or salting.

Browser Cookies or Session ID:

Cookies: Information stored on your computer by the browser

Used for tracking, Personalization, Session Management

- Not executable, not generally a security risk unless somebody gains access

Could be considered a privacy risk, as they hold lots of personal data

Session IDs are often stored in cookies

Header Manipulation:

Information gathering: Wireshark, Kismet

Exploits: Cross-site scripting

Monitor headers / cookies

Prevent Session Hijacking:

Encrypt end-to-end (Everything)

- They can't capture your session ID if they can't see it

- Additional load on the server

- Firefox extension: HTTPS Everywhere, force TLS

- Most sites are HTTPS only now

Encrypt end-to-server (mostly)

- At least audio comes over a local wireless network

- Still in the clear perhaps

- Personal VPN

Malicious Code: 2.4

An attacker can use many techniques

- Social engineering
- Default Credentials
- Misconfiguration

These don't require much skill

There are still ways to get into a well secured system

- Utilizing Malicious code

Malicious Code:

The attackers use an opportunity

- Very broad term

Many different forms:

- Executables, scripts, macro viruses, worms, trojan horses, etc.

Protection comes in many forms

- Anti-Malware
- Firewall
- Continuous updates and patching
- Secure computing habits

Malicious Code Examples

WannaCry ransomware

- Contained a Vulnerable in Windows SMBv1
- Arbitrary code execution

British Airways xmas

- 22 lines of Malicious JS code placed on checkout pages
- Information stolen from 380,000 users

Estonia Central Health Database

- SQL injection
- Breached All healthcare info for an entire country

Application Attacks: 2.4

Injection Attacks:

Code injection: Adding your own malicious code information into a data stream

Enabled due to bad programming: The application should properly handle input & output

Many different injectable files

- HTML, SQL, XML, LDAP, etc

Buffer overflow:

Overwriting a buffer or memory

- Spills over into other data areas

Developers need to perform bounds checking

Not a simple exploit at all

- May crash, takes time to work

A reliable buffer overflow is incredibly powerful

- System can be easily compromised

Replay Attack:

Useful information stolen off network

Needs access to the raw network data

- Network TAP, ARP Poisoning

NOT an on-path attack

Privilege Escalation:

Gain higher level access to a system

- Exploiting Vulnerabilities / bug or flaw

Higher level Access yields more capabilities

High Priority Vulnerability Patches

Horizontal Privilege Access

- User A can Access User B Resources

Mitigating Privilege Execution:

Patch Quickly

Update Anti Virus - Anti Malware

Data Execution Prevention

Address space layout randomization

- Prevent a buffer overrun at a known memory address

Example of a Privilege Escalation Vulnerability:

- CVE 2023-29886

- Win32k Execution Vulnerability

Attacker gains System Privilege

- Highest level of Access

Cross-Site Requests:

Cross site requests are common and legitimate

- Example: ProfMess.com

- Browser loads text/video

HTML on ProfMess.com directs requests from our browser

- Normal and expected

- Unauthorized

The Client and the Server:

Website consists of both client and server code

Client side: Renders the page on screen

HTML, JS

Server side

- Performs requests from the client

- HTML, PHP

- Transfer money from one account to another

- Post a video from Youtube

Cross Site Request Forgery (XSRP/CSRF)

One Click attack, Session Hijacking

Takes Advantage of trust that a web app has for its user

- The Website trusts your browser
- Requests are made without your consent or knowledge
- Attacker posts a Facebook status on your account

Significant Web App development oversight:

The application should have anti-forgery measures

- Usually a cryptographic token to prevent a forgery

Directory Traversal:

Read files from a web server that are outside the websites file directory

Users should not be able to browse writers folder

Web Software Server Vulnerability

- Want stop users from browsing past the web server root

Web Application Code Vulnerability

"../" indicative of directory traversal

Cryptographic Attacks: 2.4

You've encrypted + sent data. Is it secure?

The attacker doesn't have access to the combination (the key)

So they break the cryptography itself (the code)

Finding ways to undo the ciphertexts

- Math issue resides in the implementation (keysize length)

Birthday Attack:

In a classroom of 23 students what is the chance of two students sharing a birthday?

- About 50%.
- For a class of 30 about 75%.

In the digital world this is a hash collision

- Find a collision through brute force

Protect yourself with a large hash output size

Collisions:

Hash digests are supposed to be unique

- Different input data should NOT create the same hash

MD5 hash

December 2008: Researchers created a CA Cert that appeared legitimate when MD5 checked

Downgrade Attack:

Instead of using perfectly good encryption, use something not so great

- Forces the systems to downgrade their systems

SSL Stripping

- Combination of an on-path attack with a downgrade attack

- Hard to implement, but huge returns for the attacker

- Strips away the S from HTTPS

Password Attacks: 2.9

Some applications store passwords "in the clear"

- No encryption. You can read the stored password

Do NOT store passwords as plaintext

- Anyone with access has ALL credentials

Find a better application:

Hashing a Password:

Hashes represent a datum as a fixed-length of text

- A message digest or "fingerprint"

Will not (hopefully have collisions)

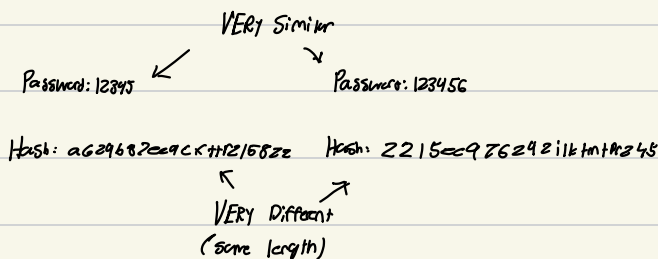
One way trip

- Impossible to recover the original message from the number

- Very common way to store passwords

Hash Example:

SHA-256 Hash: Used in many applications



The Password file:

Different across operating systems

- Different hashing algorithms
- May display username but not password

Spitting Attack:

Try to login with an incorrect password

- Eventually you are logged out

Attacker accounts with the top three (or more) passwords

- If they don't work, move on to the next account
- No lockouts, alarms, no alerts
- 123456, 123456789, QWERTY, Password

Brute Force:

Try every feasible password combination

May take immense time

Attacker downloads hash, and attempts to recreate it: Suppose hash: a7296

aaaa: x

aaab: x

...

password a7296

Brute Force

Brute Force Attacks - Online

- Keep trying login process
- Very slow
- Most accounts will lockout after a failed attempt

Brute Force the Hash-Offline

Obtain list of users & hashes

- Calculate Password hash, compare it to a stored hash
- Large computation, reduce password

Indicators Of Compromise: 2.4

An event that indicates an intrusion (IOC)

- Confidence is high

Indicators

- Unusual amount of network activity

- Change to file hash values

- Changes to DNS data

- Uncommon login patterns

- Spike of reset requests

Account lockout:

Credentials are not working, warning you

Exceeds login attempts

Account was administratively disabled

This may be a part of a larger play

- Attacker locks account

- Calls support line to reset the password

Concurrent Session Usage:

Challenging to be two places at once

Multiple logins from multiple locations

This can be difficult to track down

- Multiple devices and desktops

- Automated Process

Blocked Content:

An attacker wants to stay as long as possible

- Your system has been unlocked

There's probably a security policy violation

Blocked Content

- Links to third party pages

- Links to security policies

- Removal tools

Impossible Travel:

Authentication logs can be telling

- Login & Logout

Login from Nebraska, US

Three minutes later in Australia

Should be easy to identify, but don't forget

Resource Consumption:

Every attackers action has on casual and opposite reaction

File transfers use bandwidth

Firewalls logs show outgoing transfer

Often the first real notification of an issue

Resource Inconsistency:

The server is down

Network Disruption: Could be a disruption

Server outage: Result of exploit gone wrong

Encrypted data: Perhaps reconnaissance

Brute Force Attack

Out-of-Cycle Logging:

Occurs at unexpected time

OS Patch logs

• Occuring outside of Normal time

Firewall log activity

• Timestamps of every traffic flow

• Protocols and applications use

Missing Log Information:

Attackers delete logs to cover their tracks

• Information logs

• File Access Logs

• Firewall logs

• Proxy logs

Published / Documented:

The entire attack and exfiltration goes live

Company data will go online

• Attackers Post Portions of ALL data

Raw data may be released without context

Segmentation and Access Control: 2.5

Physical, logical, Or Virtual Segmentation

- Devices, VLANs, Virtual Networks

Performance

- High bandwidth applications

Security:

- Users Should Not be Communicating to database Server
- The only computers in the core are SAK and SBT

Compliance

- Mandated Segmentation (PCI Compliance)

Access Control List:

Allow or disallow traffic

- Grouping of categories
- Source IP, Destination IP, Port Number, time of day, etc.

Restrict Access to Network device

- Limit by IP or other identifier

Be Cautious When Configuring these

- Can lock Yourself out

Access Control Lists:

List the Permissions:

- Bob can read files
- Fred can access the network
- James can access network 192.168.1 only using for ports 80, 443, and 8080

Many OS use ACLs to provide fine access

Allow List / Deny List:

Any application can be dangerous

- Vulnerabilities, Trojan horses, malware

Allow List: Nothing runs unless it's allowed

Deny List: Nothing runs on this list

- Anti-virus / Anti-malware

Examples of Allow / Deny Lists:

Decisions are made in the operating system

Application Heuristics: Only allows applications with this unique identifier

Certificate: Allow digitally signed apps from particular publishers

Pattern: Only allow apps from these folders

Network Zones: Only run in this zone

Mitigation Techniques: 2.5

The Process of reducing the impact of an event

Penetration is Incredibly Intentional

Monthly Updates: Windows

Third Party Updates

Also critical: Not always to best

Emergency Out-of-band Updates

Encryption:

Integrated into some file systems itself

File Level Encryption: EFS

Full Disk Encryption (FDE)

- Encrypt EVERYTHING on the device

- BitLocker, or FileVault

Application Data Encryption

- Managed by the app, stored data is encrypted

Monitoring:

Aggregate information from devices

- Built-in sensors or separate devices
- Integration into sensors, switches, routers, firewalls

Sensors: Intrusion Prevention Systems, Firewall logs, Auth logs, Web access logs

Collectors:

- Proprietary Sensors (IDS, Firewall), SIEM Sensors
- Many SIEMs include a correlation engine to correlate diverse sensor data

Least Privilege:

Rights and Permissions should be the least minimum

- Only get what's needed

All accounts must be limited

- Apps should run with minimum privilege

Don't allow users to run with admin privilege

- Limits scope of malicious behavior

Configuration Enforcement:

Perform a posture assessment, each time a device connects

- Extensive Check
- OS Patch Ver
- FDR (Endpoint Detection and Response) version
- Status of Firewall
- Cert Status

Systems out of Compliance or Quarantined

- Set to Private VLAN
- Recheck after making changes

Decommissioning:

Should be a formal Policy

- Don't throw data in trash

Mostly Associated with Storage device

Many others:

- Recycle
- Destroy the device

Hardening Techniques: 2.5

Many and Varied

- Windows, Linux, iOS, Android, et al.

Updates

- Patches, System Updates, etc...

User Accounts

- Minimum Password length / Complexity
- Account Limitations

Network Access + Security

- Limit Network Access

Monitor + Secure

- Anti Virus / Malware

Encryption:

File System encryption

Full disk Encryption (FDE)

Encrypt all network data

- VPN (Virtual Private Network)

The end points:

The users Access, Apps/Data

Stop the attackers

- Inbound /outbound attacks

Many different Platforms

Many different defense teams

Endpoint detection and Response (EDR)

Detect a threat:

- Signatures
- Behavioral analysis, Machine learning, Process monitors
- Lightweight agent at the endpoint

Investigate Threat

- Root cause Analysis

Respond to the threat

- Isolate the system, quarantine, rollback
- APE driven

Host-Based Firewall:

Software Based, Personal Firewall

Allow or disallow incoming or outgoing application traffic

Identify and block unknown processes

Manage centrally

Finding Intrusions:

Host Based Intrusion Systems (HIPS)

- Recognize & block known attacks
- Secure OS and application configs

HIPS Identification

- Signatures, heuristic behavior
- Buffer overflows, registry updates
- Access to non-encrypted data

Opening Ports & Services:

Every Port is a Potential entry point

- Close everything except needed ports

Control Access with Firewall: NGFW

Unusual or Unknown Services

Applications with huge ranges, use NMAP to verify

- 0-65535

Default Password Changes:

Every Network Controls Management interface

Change default Settings (Mikrotik)

Add additional security

· MFA, 2FA

Removal of Unsecured Software:

All Software contains bugs, some of which are threatening

To circumvent issue, Replace all critical Software.

· Easy Fix!